

Výstupy ŠVP

INF-19a Chráním digitální zařízení a digitální obsah před poškozením či zneužitím s vědomím změn v technologiích, které ovlivňují bezpečnost.
(Informatika 4, 2/2 · z INF-19)

Učivo: bezpečnost počítačových zařízení a dat

Základní pojmy

Malware – Škodlivý software: virus (připojí se k souboru), červ (šíří se sám sítí), trojský kůň (tváří se jako užitečný program), ransomware (zašifruje data a žádá výkupné), spyware (sleduje uživatele).

Sociotechnika – Manipulace člověka, aby sám vydal údaje nebo udělal chybu; využívá naléhavost, autoritu, strach, zvědavost a odměnu.

Phishing – Podvodná zpráva nebo web napodobující důvěryhodnou instituci s cílem získat přihlašovací údaje či peníze; vishing = telefonem, smishing = SMS, spear phishing = cílený na konkrétního člověka.

Útoky na hesla – Hrubá síla (všechny kombinace), slovníkový útok (běžná hesla a slova), credential stuffing (uniklá hesla zkoušená na jiných službách).

Síla hesla – Počet hesel, která musí útočník vyzkoušet: $N = k^n$ (variací s opakováním, H50), v bitech $\log_2 N$ – platí jen pro náhodně zvolené heslo.

Správce hesel – Šifrovaný trezor hesel chráněný jedním hlavním heslem; vygeneruje a pamatuje si dlouhá, náhodná a pro každou službu jiná hesla.

Vícefaktorové ověření – Přihlášení dvěma různými typy faktorů: něco znám (heslo, PIN), něco mám (telefon s aplikací, bezpečnostní klíč), něco jsem (otisk, obličej).

Aktualizace – Záplata známých zranitelností; zranitelnost nultého dne (zero-day) je ta, na kterou oprava ještě neexistuje.

Antivir a firewall – Antivir hledá a blokuje škodlivý kód; firewall řídí, jaká síťová spojení smí do zařízení a ven.

Záloha – Kopie dat na jiném médiu a místě, ze které lze data obnovit po ztrátě, poruše nebo útoku ransomwaru.

Vzorce a vztahy

$N = k^n$ počet hesel délky n z abecedy k znaků ($k = 26$ malá, 62 s velkými a číslicemi, 95 se speciálními)

$b = \log_2 N = n \log_2 k$ síla hesla v bitech; každý znak z 95 přidá asi 6,6 bitu

$N = s^m$ frázové heslo z m náhodně zvolených slov ze slovníku s slov

$t = \frac{N}{v}$ doba vyzkoušení všech hesel při v pokusech za sekundu (průměrně polovina)

Náhodné heslo proti útoku 10^{10} pokusů/s (uniklá databáze)

Heslo	N	Bity	Nejdéle
PIN, 4 číslice	10^4	13	okamžitě
8 malých písmen	$2,1 \cdot 10^{11}$	38	21 s
8 znaků z 62	$2,2 \cdot 10^{14}$	48	6 h
8 znaků z 95	$6,6 \cdot 10^{15}$	53	8 dní
4 slova ze 7 776	$3,7 \cdot 10^{15}$	52	4 dny
12 znaků z 62	$3,2 \cdot 10^{21}$	72	10 000 let
6 slov ze 7 776	$2,2 \cdot 10^{23}$	78	700 000 let

Poučky a postupy

- Délka pomáhá víc než složitost: každý znak navíc násobí počet možností k -krát. Heslo ale musí být náhodné – slovníky útočníků obsahují miliardy uniklých hesel.
- Pro každou službu jiné heslo; hesla drž ve správci hesel, hlavní heslo dlouhé frázové.
- Vícefaktorové ověření zapni aspoň u e-mailu, sociálních sítí a bankovníctví – přes e-mail se obnovují všechny ostatní účty.
- Aktualizuj systém i aplikace hned (automaticky); záplata zveřejní zranitelnost a útočníci ji rychle zneužijí u neaktualizovaných zařízení.
- Zálohuj podle pravidla 3-2-1: 3 kopie dat, 2 různá média, 1 mimo domov; aspoň jednu odpojenou a občas zkus obnovu.
- Phishing: při naléhavosti zpomal, zkontroluj odesílatele a skutečnou doménu odkazu; údaje zadávej jen na webu, na který jdeš sám.
- Banka, škola ani „IT oddělení“ nikdy nechtějí tvé heslo ani kód z SMS.

Pozor na

- „Heslo123!“ splní pravidla, ale je ve slovnících útočníků – složitost není náhodnost.
- Doménu čti odzadu od první lomky: v adrese banka.cz.overeni-uctu.example je skutečná doména overeni-uctu.example.
- Pozor na dvojí příponu (faktura.pdf.exe) a dokumenty s makry od neznámých odesílatelů.
- Záloha trvale připojená k počítači může ransomware zašifrovat také.
- Zámek (https) v prohlížeči jen říká, že spojení je šifrované – ne že web je poctivý.

Vzorový příklad

Útočník získal uniklou databázi a zkouší 10^{10} hesel za sekundu. Jak dlouho mu trvá vyzkoušet všechna 8znaková hesla z malých a velkých písmen a číslic? A 12znaková?

- Abeceda: $k = 26 + 26 + 10 = 62$ znaků; $n = 8$:
 $N = 62^8 \doteq 2,18 \cdot 10^{14}$.
- $t = \frac{N}{v} = \frac{2,18 \cdot 10^{14}}{10^{10}} \doteq 21\,800\text{ s} \doteq 6\text{ h}$ (průměrně asi 3 h).
- $n = 12$: $N = 62^{12} \doteq 3,2 \cdot 10^{21}$, $t \doteq 3,2 \cdot 10^{11}\text{ s} \doteq 10\,000\text{ let}$.
- V bitech: $8 \cdot \log_2 62 \doteq 47,6$ bitu proti 71,5 bitu – 4 znaky navíc = $62^4 \doteq 1,5 \cdot 10^7 \times$ víc práce.
- Závěr: délka rozhoduje, ale jen u náhodného hesla; proti úniku z jiné služby chrání jen různá hesla a vícefaktorové ověření.